

Contents

1	FUT03: 監査・コンプライアンス強化	1
1.1	0. 文書情報	1
1.2	1. 概要	1
1.3	2. 関連要件・候補	1
1.3.1	2.1 要件候補 (将来 FR)	1
1.3.2	2.2 基本設計論点	2
1.3.3	2.3 詳細設計バックログ	2
1.4	3. 影響範囲	3
1.5	4. 実施条件	3
1.6	5. 関連設計	3
1.7	6. 未確定事項・確認事項	4

1 FUT03: 監査・コンプライアンス強化

1.1 0. 文書情報

項目	内容
文書名	FUT03: 監査・コンプライアンス強化
将来対応 ID	FUT-03
対象システム	FAQ AI ウィジェット SaaS / 運営者システム
作成日	2026-05-17
版数	v1.0
ステータス	検討中 (MVP 外)

1.2 1. 概要

項目	内容
概要	MVP では 3 操作ハードゲート + 7 操作承認ログのみ / 監査ハッシュチェーン基盤・3 区分保持 (運営者正本) / GDPR 対応最小限で運用している監査・コンプライアンス領域について、Post-MVP で 4-eyes 全 10 操作ワークフロー化 / バイパス削除 / GDPR 強化 / 越境移転ガード / 監査ハッシュチェーン拡張を整備する。
背景	内部統制レビュー、第三者監査 (SOC 2 等)、海外顧客の GDPR / CCPA 要件、エンタープライズ契約獲得には、4-eyes 完全強制および監査・コンプライアンスの段階強化が必要となる。
期待効果	承認バイパスリスクの完全排除、海外顧客の規制適合、第三者監査受審可能性、監査証跡の改ざん耐性強化。
優先度 (将来対応内)	高
想定時期	T2(ベータ判定まで)~T3(GA 判定まで)

1.3 2. 関連要件・候補

1.3.1 2.1 要件候補 (将来 FR)

1.3.1.1 認証・セキュリティ (運営者関連分・4-eyes 完全強制)

ID	要件候補	MVP の前提	判定時期	判定基準 / 完了条件
FUT-REQ-SEC-003	4-eyes 原則の完全強制	3 操作をハードゲート化し、7 操作は承認ログのみ	ベータ / GA	ベータで全 10 操作ワークフロー化、GA でバイパス禁止。SCR-096 の承認バイパス検出 KPI が 4 週間連続 0 件

1.3.1.2 国際化・リージョン (GDPR / 越境移転関連)

ID	要件候補	MVP の前提	判定時期	判定基準 / 完了条件
FUT-REQ-I18N-002	マルチリージョン	日本リージョン (apac) のみ	ベータ / GA	ベータで region 属性導入を評価し、GA で apac / wnam / eur などの選択可否を判定 (GDPR 越境移転ガードと整合)

1.3.1.3 FR / NFR 段階導入 (運営者関連分)

由来 ID	MVP 仕様	ベータ仕様	GA / Post-MVP 仕様
4-eyes	3 操作ハードゲート + 7 操作承認ログ	全 10 操作ワークフロー化	バイパス禁止
RB-014	物理金庫 + 紙ベース回復コード + 2 名立会	継続	API 化 + 申請ログ・事後監査強化

1.3.2 2.2 基本設計論点

1.3.2.1 認証・セキュリティ (運営者関連分)

項目	基本設計で具体化すること	関連 Future 要件
4-eyes 完全強制	10 操作の申請・承認・実行状態、SCR-096 のバイパス検出 KPI、緊急例外 RB-014 との分岐	FUT-REQ-SEC-003

1.3.2.2 国際化・リージョン (越境移転ガード関連)

項目	基本設計で具体化すること	関連 Future 要件
マルチリージョン	契約発行時の region 決定、データ配置、越境移転ガード、運営者画面での region 表示	FUT-REQ-I18N-002

1.3.3 2.3 詳細設計バックログ

1.3.3.1 実装設計バックログ (監査・コンプライアンス関連分)

ID	対象	実装設計で具体化すること	関連 Future 要件
FUT-DD-SEC-003	4-eyes 完全強制	operator_approvals の対象操作拡張、状態遷移、承認者重複防止、バイパス削除、E2E	FUT-REQ-SEC-003
FUT-DD-I18N-002	マルチリージョン (越境移転ガード)	accounts.region、routing、D1/R2 配置、region guard、越境拒否 API	FUT-REQ-I18N-002

1.3.3.2 マルチリージョン / 越境移転ガード (DDL 候補)

```
ALTER TABLE accounts
  ADD COLUMN region TEXT NOT NULL DEFAULT 'apac'
  CHECK (region IN ('apac', 'wnam', 'eur'));
```

```
CREATE TABLE owner_region_audit_logs (
  id TEXT PRIMARY KEY,
  owner_account_id TEXT NOT NULL,
  before_region TEXT NOT NULL,
  after_region TEXT NOT NULL,
  approved_by TEXT NOT NULL,
  reason TEXT NOT NULL,
  created_at TEXT NOT NULL
);
```

1.3.3.3 API / Worker 候補 (関連分)

領域	候補
4-eyes	POST /admin/v1/operator-approvals、POST /admin/v1/operator-approvals/{id}/approve、POST /admin/v1/operator-approvals/{id}/execute
マルチリージョン	TenantRegionGuard、POST /admin/v1/owners/{id}/region-approval

1.3.3.4 テスト・検証候補 (関連分)

領域	検証項目
4-eyes	申請者 = 承認者禁止、承認期限切れ、二重実行防止、緊急例外、監査ログ
マルチリージョン	region guard、越境拒否、D1/R2 配置、監査ログの region 記録

1.4 3. 影響範囲

種別	影響内容
要件	4-eyes 原則 (3 操作 → 全 10 操作)、GDPR / 越境移転 (region 属性導入)、監査ハッシュチェーン (運営者正本) 拡張
画面	SCR-APPROVALS (全 10 操作申請・承認・実行 UI)、SCR-096 (承認バイパス検出 KPI ダッシュボード)、運営者画面での region 表示、越境移転承認画面
API	POST /admin/v1/operator-approvals、POST /admin/v1/operator-approvals/{id}/approve、POST /admin/v1/operator-approvals/{id}/execute、TenantRegionGuard ミドルウェア、POST /admin/v1/owners/{id}/region-approval
テーブル	operator_approvals 対象操作拡張 (7 操作追加)、accounts.region 列追加、owner_region_audit_logs、audit_logs.retention_class (general / billing / operator_high_priv) ・ハッシュチェーン拡張
運用	4-eyes 全 10 操作ワークフロー運用、SCR-096 承認バイパス検出 KPI (4 週間連続 0 件) 監視、越境移転ガード運用、GDPR データ削除要求 (DSR) 対応手順、監査ハッシュチェーン第三者検証手順

1.5 4. 実施条件

項目	内容
実施判断条件	4-eyes はベータで全 10 操作ワークフロー化 + GA でバイパス禁止 (SCR-096 承認バイパス検出 KPI 4 週間連続 0 件)、GDPR / 越境移転ガードはマルチリージョン導入と同時に確定
期限	T2 (全 10 操作ワークフロー化、PII NER 第 2 層によるログ強化)、T3 (バイパス API 削除、緊急例外 RB-014 限定、GDPR / 越境移転ガード、監査ハッシュチェーン拡張)
依存関係	共有概念の 4-eyes 承認基盤 (運営者正本) ・ハッシュチェーン監査 (運営者正本) ・IP allowlist (運営者正本)、メイン側 PII 暗号化 (メイン正本)、運営者システム 10 セキュリティ設計書 § 7、04 テーブル定義書 (operator_approvals / audit_logs)、09 認証認可設計書 § 7

1.6 5. 関連設計

種別	参照先
要件	../01_要件定義/index.md
基本設計	../02_基本設計/index.md
詳細設計	../03_詳細設計/index.md
運用設計	../04_運用設計/index.md
共有概念 (正本)	../共有/共有概念.md

1.7 6. 未確定事項・確認事項

確認事項 ID	確認内容	優先度	ステータス
FUT-AUDIT-Q-001	4-eyes 全 10 操作のワークフロー化対象(現状 7 操作 = 承認ログのみ)の最終リスト確定	高	検討中
FUT-AUDIT-Q-002	バイパス API 削除時の緊急例外手段(RB-014 物理金庫のみで運用可能か)	高	検討中
FUT-AUDIT-Q-003	GDPR DSR(データ削除要求) 対応手順と audit_logs.retention_class との整合	高	検討中
FUT-AUDIT-Q-004	越境移転ガードでの region 変更 / 移行手順(EU → APAC 等)	中	検討中
FUT-AUDIT-Q-005	監査ハッシュチェーン第三者検証(オプション) 導入時の公開範囲	中	検討中
FUT-AUDIT-Q-006	SCR-096 承認バイパス検出 KPI 監視ダッシュボード仕様	中	検討中